Mobile Security



Intense overview of mobile security

threat

Fabio Pietrosanti

Who am i



- Passion in hacking, security, intelligence and telecommunciations
- CTO & Founder at PrivateWAVE . We do mobile voice encryption
- Playing with security since ’95 as “naif”
- Playing with mobile since 2005

Key points & Agenda

- 1 Difference between mobile security & IT security
- 2 Mobile Device Security
- 3 Mobile hacking & attack vector
- 4 The economic risks
- 5 Conclusion

Mobile Security

Introduction

Mobile phones today

- Mobile phones changed our life in past 15 years (GSM & CDMA)
  - Mobile phones became the most personal and private item we own
- Mobile smartphones change our digital life in past 5 years
  - Growing computational power of “phones”
  - Diffusion of high speed mobile data networks
  - Real operating systems run on smartphones

Mobile phones today

symbian OS

BlackBerry

Windows Mobile





It’s something personal



- Mobile phones became the most personal and private item we own
- Get out from home and you take:
  - House & car key
  - Portfolio
  - Mobile phone

It's something critical

- phone call logs
- addressbook
- emails
- sms
- Mobile browser history
- documents
- calendar

- Voice calls cross trough it (volatile but non that much)
- Corporate network access
- GPS tracking data

Mobile Security

Difference between mobile security & IT security

Too much trust

- Trust between operators
- Trust between the user and the operators
- Trust between the user and the phone



- Still low awareness of users on security risks

Difference between mobile security & IT Security

Too difficult to deal with

- Low level communication protocols/networks are closed (security trough entrance barrier)
- Too many etherogeneus technologies, no single way to secure it
  - Diffused trusted security but not omogeneous use of trusted capabilities
- Reduced detection capability of attack & trojan

Difference between mobile security & IT Security

Too many sw/hw platforms

- Nokia S60 smartphones
  - Symbian/OS coming from Epoc age (psion)
- Apple iPhone
  - iPhone OS - Darwin based, as Mac OS X - Unix
- RIM Blackberry
  - RIMOS – proprietary from RIM
- Windows Mobile (various manufacturer)
  - Windows Mobile (coming from heritage of PocketPC)
- Google Android
  - Linux Android (unix with custom java based user operating environment)

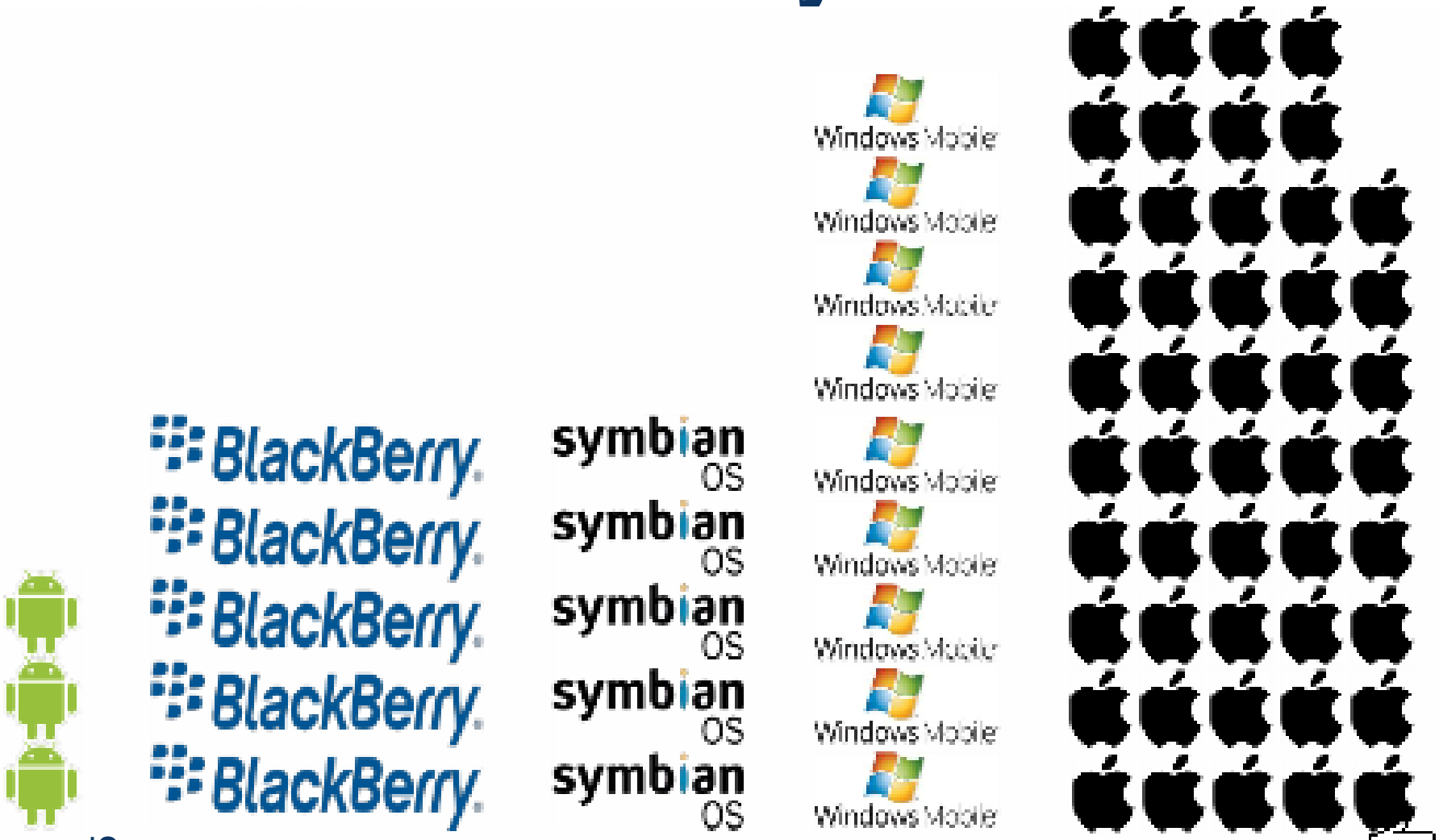
Difference between mobile security & IT Security

Vulnerability management

- Patching mobile operating system is difficult
  - Carrier often build custom firmware, it's at their costs and not vendor costs
  - Only some environments provide easy OTA software upgrades
  - Almost very few control from enterprise provisioning and patch management perspective
  - Drivers often are not in hand of OS Vendor
  - Basend Processor run another OS
  - Assume that some phones will just remain buggy

Difference between mobile security & IT Security

Vulnerability count



Source: iSec

Mobile Security

Mobile Device Security

Devices access and authority

- All those subject share authority on the device
  - OS Vendor/Manufacturer (2)
  - Carrier (1)
  - User
  - Application Developer

(1) Etisalat operator-wide spyware installation for Blackberry
http://www.theregister.co.uk/2009/07/14/blackberry_snooping/

(2) Blackberry banned from france government for spying risks
http://news.bbc.co.uk/2/hi/business/6221146.stm

Reduced security by hw design

- Poor keyboard ->
- Poor password

Type a passphrase:

P4rtyn%!ter.nd@'01



Reduced security by hw design

- Poor screen, poor control
- User diagnostic capabilities are reduced. No easy checking of what's going on
- Critical situation where user analysis is required are difficult to be handled (SSL, Email)





Mobile security model – old school

- Windows Mobile and Blackberry application
  - Authorization based on digital signing of application
  - Everything or nothing
  - With or without permission requests
  - Limited access to filesystem
- No granular permission fine tuning

Cracking blackberry security model with 100$ key

http://securitywatch.eweek.com/exploits_and_attacks/cracking_the_blackberry_with_a_100_key.html

Mobile security model – old school but Enterprise

- Windows Mobile 6.1 (SCMDM) and Blackberry (BES)
  - Deep profiling of security features for centrally managed devices
    - Able to download/execute external application
    - Able to use different data networks
    - Force device PIN protection
    - Force device encryption (BB)
    - Profile access to connectivity resources (BB)

Mobile security model – iPhone

- Heritage of OS X Security model
- Centralized distribution method: appstore
- Technical application publishing policy
- Non-technical application publishing policy

AppStore “is” a security feature

- NO serious enterprise security provisioning

Mobile security model – Android / Symbian

- Sandbox based approach (data caging)
- Users have tight control on application permissions
  - Symbian so strict on digital signature enforcement but not on data confidentiality
  - Symbian require different level of signature depending on capability usage
- Android support digital signing with self-signed certificates but keep java security model
  - A lot of third party security application
- NO serious enterprise security provisioning

Brew & NucleOS

- Application are provided *exclusively* from mnu facturer and from operator
- Delivery is OTA trough application portal of operator
- Full trust to carrier

Development language security

- Development language/sdk security features support are extremely relevant to increase difficulties in exploiting

Blackberry RIMOS	**J2ME MIDP 2.0**	**No native code**
Iphone	**Objective-C**	**NX Stack/heap protection**
Windows Mobile	**.NET / C++**	**GS enhanced security**
Nokia/Symbian	**C++**	**Enhanced memory management**
Android/Linux	**Java & NDK**	**Java security model**

Mobile Security

Mobile Hacking
&
Attack vector

Mobile security research

- Mobile security research exponentially increased in past 2 years
  - DEFCON (USA), BlackHat (USA, Europe, Japan), CCC(DE), ShmooCon (USA), YSTS (BR), HITB (Malaysia), CansecWest (CAN), EuSecWest)NL, GTS(BR), Ekoparty (AR), DeepSec (AT) *CLCERT data
- Hacking environment is taking much more interests and attention to mobile hacking
- Dedicated security community:
  - TSTF.net , Mseclab , Tam hanna

Mobile security research - 2008

- DEFCON 16 - Taking Back your Cellphone Alexander Lash
- BH DC / BH Europe – Intercepting Mobile Phone/GSM Traffic David Hulton, Steve–
- BH Europe - Mobile Phone Spying Tools Jarno Niemelä–
- BH USA - Mobile Phone Messaging Anti-Forensics Zane Lackey, Luis Miras
- Ekoparty - Smartphones (in)security Nicolas Economou, Alfredo Ortega
- BH Japan - Exploiting Symbian OS in mobile devices Collin Mulliner–
- GTS-12 - iPhone and iPod Touch Forensics Ivo Peixinho
- 25C3– Hacking the iPhone - MuscleNerd, pytey, planetbeing
- 25C3 Locating Mobile Phones using SS7 – Tobias Engel– Anatomy of smartphone hardware Harald Welte
- 25C3 Running your own GSM network – H. Welte, Dieter Spaar
- 25C3 Attacking NFC mobile phones – Collin Mulliner

Mobile security research 2009 (1)

- ShmooCon Building an All-Channel Bluetooth Monitor Michael Ossmann and Dominic Spill
- ShmooCon Pulling a John Connor: Defeating Android Charlie Miller
- BH USA– Attacking SMS - Zane Lackey, Luis Miras –
- BH USA Premiere at YSTS 3.0 (BR)
- BH USA Fuzzing the Phone in your Phone - Charlie Miller, Collin Mulliner
- BH USA Is Your Phone Pwned? - Kevin Mahaffey, Anthony Lineberry & John Hering–
- BH USA Post Exploitation Bliss –
- BH USA Loading Meterpreter on a Factory iPhone - Vincenzo Iozzo & Charlie Miller–
- BH USA Exploratory Android Surgery - Jesse Burns
- DEFCON 17– Jailbreaking and the Law of Reversing - Fred Von Lohmann, Jennifer Granick–
- DEFCON 17 Hacking WITH the iPod Touch - Thomas Wilhelm
- DEFCON 17 Attacking SMS. It's No Longer Your BFF - Brandon Dixon
- DEFCON 17 Bluetooth, Smells Like Chicken - Dominic Spill, Michael Ossmann, Mark Steward

Mobile security research 2009 (2)

- BH Europe– Fun and Games with Mac OS X and iPhone Payloads - Charlie Miller and Vincenzo Iozzo–
- BH Europe Hijacking Mobile Data Connections - Roberto Gassirà and Roberto Piccirillo–
- BH Europe Passports Reloaded Goes Mobile - Jeroen van Beek
- CanSecWest– The Smart-Phones Nightmare Sergio 'shadown' Alvarez
- CanSecWest - A Look at a Modern Mobile Security Model: Google's Android Jon Oberheide–
- CanSecWest - Multiplatform iPhone/Android Shellcode, and other smart phone insecurities Alfredo Ortega and Nico Economou
- EuSecWest - Pwning your grandmother's iPhone Charlie Miller–
- HITB Malaysia - Bugs and Kisses: Spying on Blackberry Users for FunSheran Gunasekera– YSTS 3.0 /
- HITB Malaysia - Hacking from the Restroom Bruno Gonçalves de Oliveira
- PacSec - The Android Security Story: Challenges and Solutions for Secure Open Systems Rich Cannings & Alex Stamos

Mobile security research 2009 (3)

- DeepSec - Security on the GSM Air Interface David Burgess, Harald Welte
- DeepSec - Cracking GSM Encryption Karsten Nohl–
- DeepSec - Hijacking Mobile Data Connections 2.0: Automated and Improved Roberto Piccirillo, Roberto Gassirà–
- DeepSec - A practical DOS attack to the GSM network Dieter Spaar

Attack layers

- Mobile are attacked at following layers
  - Layer2 attacks (GSM, UMTS, WiFi)
  - Layer4 attacks (SMS/MMS interpreter)
  - Layer7 attacks (Client side hacking)

Layer3 (TCP/IP) is generally protected by mobile operators by filtering inbound connections

Link layer security - GSM



- GSM has been cracked with 2k USD hw equipment
  - http://reflextor.com/trac/a51 - A51 rainbowtable cracking software
  - http://www.airprobe.org - GSM interception software
  - http://www.gnuradio.org - Software defined radio
  - http://www.ettus.com/products - USRP2 – Cheap software radio

Link layer security - UMTS



- 1° UMTS (Kasumi) cracking paper by Israel's Weizmann Institute of Science
  - http://www.theregister.co.uk/2010/01/13/gsm_crypto_crack/
- Still no public practical implementation
- UMTS-only mode phones are not reliable

Link layer security – WiFi



- All known attacks about WiFi
  - Rogue AP, DNS poisoning, arp spoofing, man in the middle, WEP cracking, WPA-PSK cracking, etc



Link layer security Rouge operators roaming

- Telecommunication operators are trusted among each other (roaming agreements & brokers)
- Operators can hijack almost everything of a mobile connections:
  - mobile connect whatever network is available
- Today, becoming a mobile operators it's quite easy in certain countries, trust it's a matter of money
- Today the equipment to run an operator is cheap (OpenBTS & OpenBSC)

MMS security

- Good delivery system for malware (binary mime encoded attachments, like email)
- Use just PUSH-SMS for notifications and HTTP & SMIL for MMS retrieval
- “Abused” to send out confidential information (intelligence tool for dummies & for activist)
- “Abused” to hack windows powered mobile devices
  - MMS remote Exploit (CCC Congress 2006)

  http://www.f-secure.com/weblog/archives/00001064.html
- MMS spoofing & avoid billing attack
  - http://www.owasp.org/images/7/72/MMS_Spoofing.ppt
  - MMSC filters on certain attachments
- Application filters on some mobile phones for DRM purposes

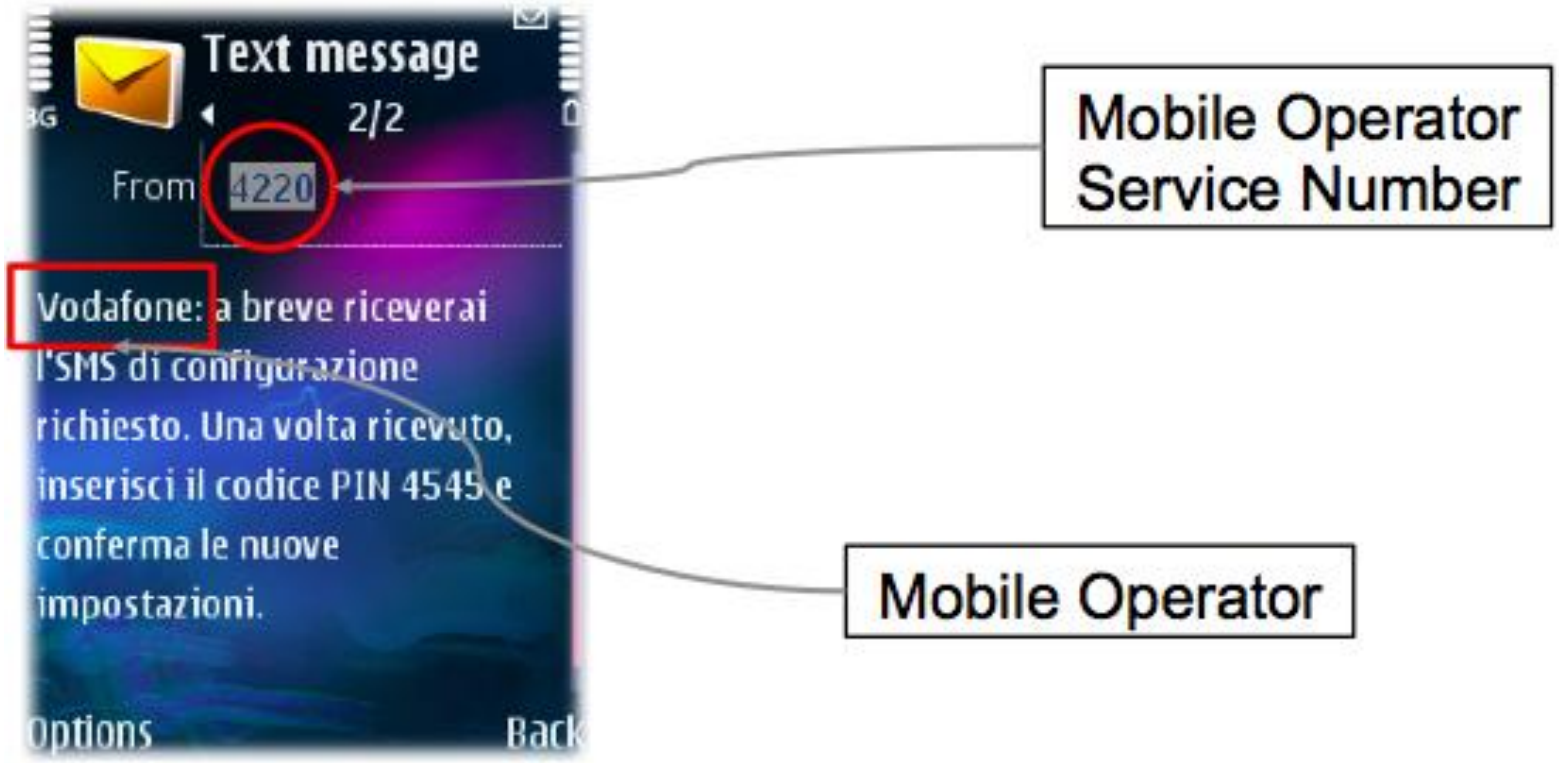
SMS security (1)

- Only 160byte per SMS (concatenation support)
- CLI spoofing is extremely easy
- **SMS interpreter exploit**
  - iPhone SMS remote exploit

  http://news.cnet.com/8301-27080_3-10299378-245.html
- **SMS used to deliver web attacks**
  - Service Loading (SL) primer
- **SMS mobile data hijacking trough SMS provisioning**
  - Send Wap PUSH OTA configuration message to configure DNS (little of social engineerings)
  - Redirection, phishing, mitm, SSL attack, protocol downgrade, etc, etc
- SMSC filters sometimes applied, often bypassed

SMS security (2)

Easy social engineering for provisioning SMS



Thanks to Mobile Security Lab http://www.mseclab.com

Bluetooth (1)

- Bluetooth spamming (they call it, “mobile advertising”)
- Bluetooth attacks let you:
  - initiating phone calls
  - sending SMS to any number
  - reading SMS from the phone
  - Reading/writing phonebook
  - setting call forwards
  - connecting to the internet



- Bluesnarfing, bluebug, bluebugging

http://trifinite.org/

- Bluetooth OBEX to send spyware

Bluetooth (2)

- Bluetooth encryption has been cracked

http://news.techworld.com/security/3797/bluetooth-crack-gets-serious/

- But bluetooth sniffers were expensive
- So an hacked firmware of a bluetooth dongle made it accessible: 18$ bluetooth sniffer

http://pcworld.about.com/od/wireless/Researcher-creates-Bluetooth-c.htm

- Bluetooth interception became feasible
- Bluetooth SCO (audio flow to bluetooth headset) could let phone call interception



NFC – what's that?

- Near Field Communications
  - Diffused in far east (japan & china)
  - Estimated diffusion in Europe/North America: 2013
  - Estimated financial transaction market: 75bn
  - NFC Tech: 13.56mhz, data rates 106kbit/s, multiple rfid tags
  - NFC Tag transmit URI by proximily to the phone that prompt user for action given the protocol:
    - URI
    - SMS
    - TEL
    - SMART Poster (ringone, application, network configuration)
  - NFC Tag data format is ndef
  - J2ME midlet installation is automatic, user is just asked after download already happened

NFC – example use

- NFC Ticketing (Vienna's public services)









- Vending machine NFC payment
- Totem public tourist information

NFC - security

- EUSecWest 2008: Hacking NFC mobile phones, the NFCWorm

http://events.ccc.de/congress/2008/Fahrplan/events/2639.en.html

- URI Spoofing:
  - Hide URI pointed on user
- NDEF Worm
  - Infect tags, not phones
  - Spread by writing writable tags
  - Use URI spoofing to point to midlet application that are automatically downloaded
- SMS/TEL scam trough Tag hijacking

Mobile Web Security - WAP

- HTTPS is considered a secure protocol
  - Robust and reliable based on digital certificate
- WAP if often used by mobile phones because it has special rates and mobile operator wap portal are feature rich and provide value added contents
- WAP security use WTLS that act as a proxy between a WAP client and a HTTPS server
- WTLS in WAP browser break the end-to-end security nature of SSL in HTTPS
- WAP 2 fix it, only modern devices and modern WAP gateway



Mobile Web Security – WEB

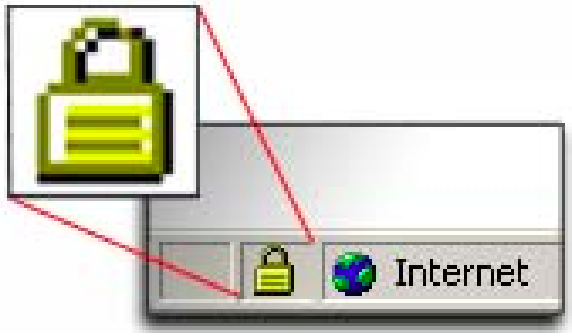
- Most issues in end-to-end security
- Attackers are facilitated
  - Phones send user-agent identifying precise mode
  - Some operator HTTP transparent proxy reveal to web server MSISDN and IMSI of the phone
- Mobile browser has to be small and fast but…
- Mobile browser has to be compatible with existing web security technologies

Mobile Web Security – WEB/SSL

- SSL is the basic security system used in web for HTTPS
- It get sever limitation for wide acceptance in mobile environment (where smartphone are just part of)
  - End-to-end break of security in WTLS
  - Not all available phones support it
  - Out of date Symmetric ciphers
  - Certificates problems (root CA)
  - Slow to start
  - Certificates verification problems

Mobile Web Security – SSL UI

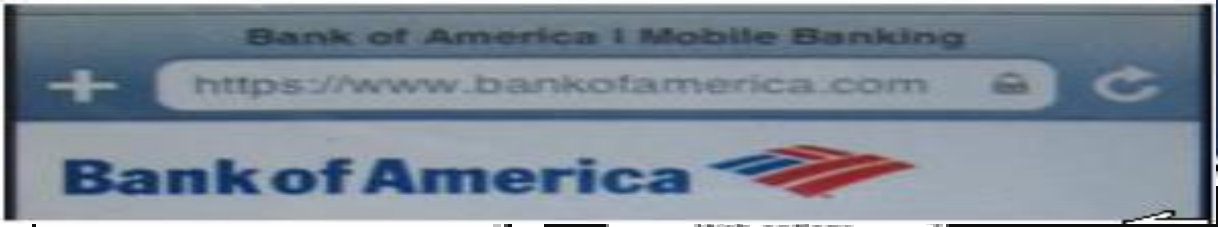
- Mobile UI are not coherent when handling SSL certificates and it may be impossible to extremely tricky for the user to verify the HTTPS information of the website
  - Details not always clear
  - From 4 to 6 click required to check SSL information
  - Information are not always consistent
  - Transcoder make the operator embed their custom trusted CA-root to be able to do Main In the Middle while optimizing web for mobile



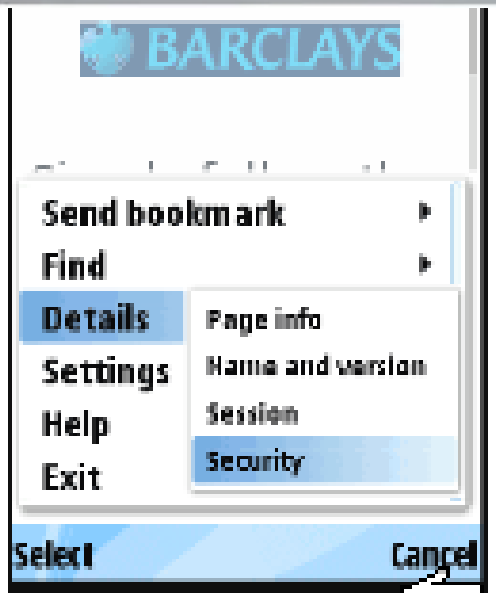
Tnx to Rsnake & Masabi

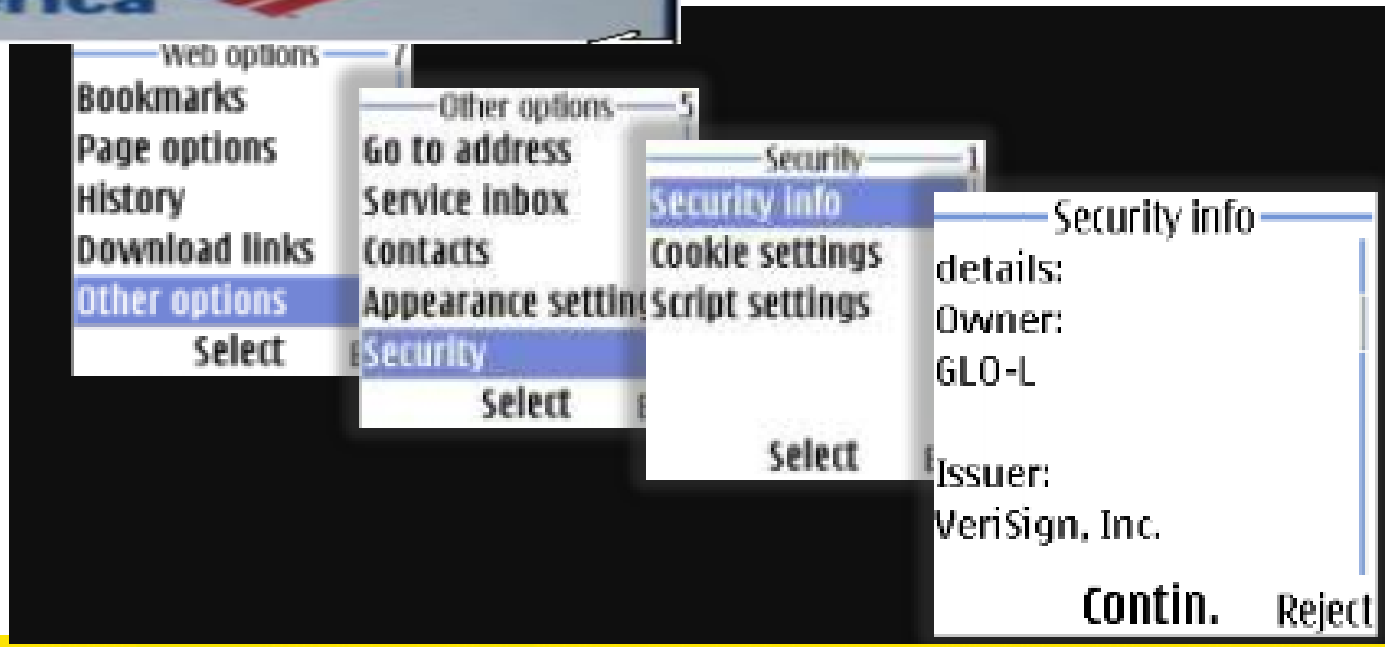
Mobile Web Security – SSL UI



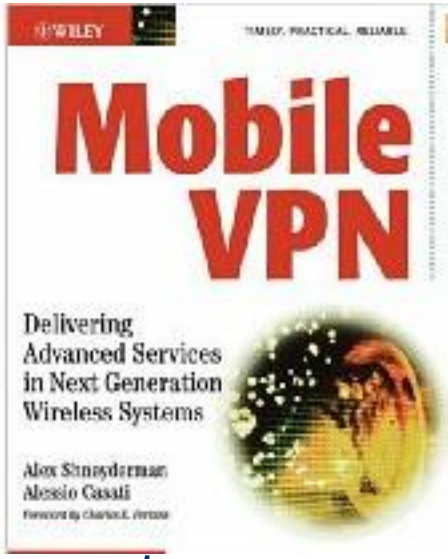








Mobile VPN



- Mobile devices often need to access corporate networks
- VPN security has slightly different concepts
  - **User managed VPN** (Mobile IPSec clients)
  - **Operator Managed VPN** (MPLS-like model with dedicated APN on 3G data networks)

    Authentication based on SIM card and/or with login/password

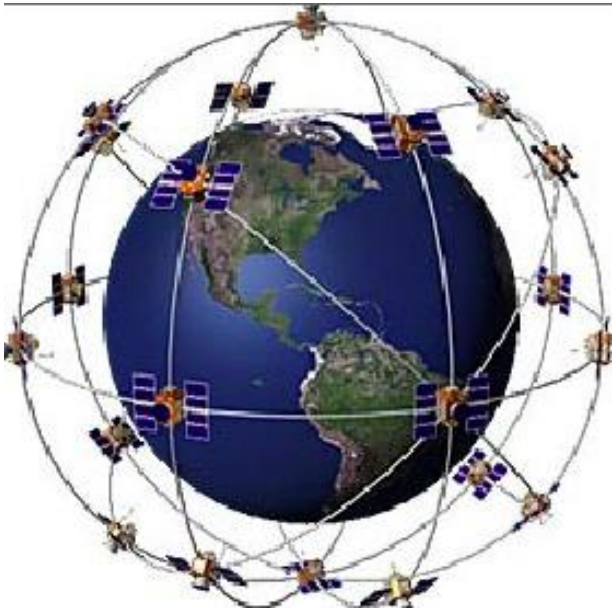
Voice interception

- Voice interception is the most known and considered risks because of media coverage on legal & illegal wiretapping
  - Interception trough Spyware injection (250E)
  - Interception trough GSM cracking (2 150.000E)



  - Interception trough Telco Hijacking (30.000E)
- Approach depends on the technological skills of the attacker
- Protection is not technologically easy

Location Based Services or Location Based Intelligence? (1)



- New risks given by official and unofficial LBS technologies
- GPS:
  - Cheap cross-platform powerfull spyware software with geo tracking (http://www.flexispy.com)
  - Gps data in photo's metadata (iphone)
  - Community based tracking (lifelook)

Location Based Services or Location Based Intelligence? (2)



- HLR (Home Location Register) MSC lookup:
  - GSM network ask the network's HLR's: where is the phone's MSC?
  - Network answer:
    {"status":"OK","number":"123456789","imsi":"220021234567890","mcc":"220",”mnc":"02","msc":"13245100001",””msc_location”:”London,UK”,”operator_name”:” Orange (UK)”,”operator_country”:”UK”}
- HLR Lookup services (50-100 EUR):
  - http://www.smssubmit.se/en/hlr-lookup.html
  - http://www.routomessages.com

Mobile malware - spyware

- Commercial spyware focus on information spying
  - Flexispy (cross-platform commercial spyware)

    Listen in to an active phone call (CallInterception)

    Secretly read SMS, Call Logs, Email, Cell ID and make Spy Call

    Listen in to the phone surrounding

    Secret GPS tracking

    Highly stealth (user Undetectable in operation)
  - A lot small software made for lawful and unlawful use by many small companies



Mobile malware – virus/worm (1)



- Worm
  - Still no cross-platform system
  - Mainly involved in phone fraud (SMS & Premium numbers)
  - Sometimes making damage
  - Often masked as useful application or sexy stuff
  - In July 2009 first mobile botnet for SMS spamming

http://www.zdnet.co.uk/news/security-threats/2009/07/16/phone-trojan-has-botnet-features-39684313/

Mobile malware – virus/worm (2)

- Malware full feature list

Spreading via Bluetooth, MMS, Sending SMS messages, Infecting files,Enabling remote control of the smartphone,Modifying or replacing icons or system applications, Installing "fake" or non-working fonts and applications, Combating antivirus programs, Installing other malicious programs, Locking memory cards, Stealing data, Spreading via removable media (memory sticks) , Damaging user data, Disabling operating system security mechanisms , Downloading other files from the Internet, Calling paid services ,Polymorphism

Source: Karspersky Mobile Malware evolution

http://www.viruslist.com/en/analysis?pubid=204792080

Mobile Forensics

- It's not just taking down SMS, photos and addressbook but all the information ecosystem of the new phone
- Like a new kind of computer to be analyzed, just more difficult
- Require custom equipment
- Local data easy to be retrieved
- Network data are not affordable, spoofing is concrete
- More dedicated training course about mobile forensics





Extension of organization: The operator

- Mobile operator customer service identify users by CLI & some personal data
- Mix of social engineering & CLI spoofing let to compromise of
  - Phone call logs (Without last 3 digits)
  - Denial of service (sim card blocking)
  - Voice mailbox access (not always)

Some near future scenarios

- Real diffusion of cross-platform trojan targeting fraud (espionage already in place)
  - Back to the era of mobile phone dialers
  - Welcome to the new era of mobile phishing
- QR code phishing:
  - “Free mobile chat, meet girls” -> http://tinyurl.com/aaa -> web mobile-dependent malware.
- SMS spamming becomes aggressive

Mobile Security

The economic risks
TLC & Financial frauds



Basic of phone fraud



- Basic of fraud
  - Make the user trigger billable events
- Basics of cash-out
  - Subscriber billable communications

    SMS to premium number

    CALL premium number

    CALL international premium number

    DOWNLOAD content from wap sites (wap billing)

Fraud against user/corporate

- Induct users to access content trough:
  - SMS spamming (finnish & italian case)
  - MMS spamming
  - Web delivery of telephony related URL (sms:// tel://)
  - Bluetooth spamming/worm
- Phone dialers back from the ‘90 modem age

The economic risks

Security of mobile banking



- Very etherogeneus approach to access & security:
  - STK/SIM toolkit application mobile banking
  - Mobile web mobile banking - **powerful phishing**
  - Application based mobile banking (preferred because of usability)
  - SMS banking (feedbacks / confirmation code)

Mobile Security Conclusion



Enterprise mobile security policies?

- Still not widely diffused
  - Lacks of general knowledge about risk
  - Lacks of widely available cross-platform tools
- Difficult to be effectively implemented
  - Application protection and privileges cannot be finely tuned across different platform in the same way
  - Only action taken is usually anti-theft and device-specific security services (such as blackberry application provisioning/protection & data encryption)

New challenges require new approach

- Mobile manufacturer, Mobile OS provider and Carriers should agree on true common standard for security
- Antifraud systems must be proactive and new technology should “secure by-design”
- Enterprises should press the market and large ITSec vendors should push on manufacturer & operators for omogeneous security solutions
- We should expect even more important attack soon

Thanks for you attention!

Questions?

- Slides will be available online
- For any contact:
  - fabio.pietrosanti@privatewave.com
  - GSM: +393401801049
  - Skype: fpietrosanti